

Maple Systems Firmware Attack Surface & Detection Brief

Scope: Research-only brief — firmware extraction is pending; no rootfs has been carved and no hashes have been baselined against NSRL. Covers 7 product lines (HMC-Series, HMI5000-Series, cMT-X-Series, EZ-Series, EZware Plus, EBPro, cMT-Viewer) grouped into 3 architecture classes. Findings combine CISA ICS advisories against the underlying Weintek OEM platform, Maple Systems vendor documentation, NVD CVE records, and named research from Team82 (Claroty), Forescout Vedere Labs, and Dragos. Treat every claim here as a *prior* to validate the moment firmware lands in `firmware-staging/maple-systems/`.

Purdue layer mapping: Group A (HMI panels) is operator-facing Purdue **L2** — see [docs/purdue-l2-area-supervisory-brief.md](#). Group B (EZware Plus + EBPro design tools) lives on the engineer/integrator EWS at **L3** — see [docs/purdue-l3-site-operations-brief.md](#). Group C (cMT-Viewer thin client) is **L3.5** when remote-access is enabled — see [docs/purdue-l35-it-ot-boundary-brief.md](#). The PLCs these panels drive (CompactLogix, M340) live at **L1** — see [docs/purdue-l1-basic-controllers-brief.md](#). No Maple product participates in a safety loop — see [docs/purdue-safety-systems-brief.md](#) for the SIS exclusion rationale.

Architecture grouping (drives the threat model, not the SKU)

Class	Purdue layer	Products	Stack	Catalog depth
A — HMI panels	L2 area supervisory	HMC4xxx/HMC7xxx, HMI5000, cMT-X / cMT3000-X, EZTouchPLC / EZ12 / EZ15	ARM Linux runtime (Weintek lineage on cMT-X); embedded RTOS on legacy HMI5000/EZ; Modbus TCP master+slave on 502; web-UI on 80/443; VNC on 5900	4 lines, firmware pending
B — Design tools	L3 site ops (EWS)	EZware Plus, EBPro	Win32 design IDE; emits <code>.cmtp</code> / <code>.empx</code> / <code>.mtp</code> project files; pushes runtime images to panel over HTTP/USB	2 tools, no firmware (PE binaries)
C — Remote	L3.5 IT/OT boundary	cMT-Viewer (Win / iOS / Android)	TLS-fronted Weintek cloud relay (EasyAccess 2.0 lineage);	1 client, no firmware

Class	Purdue layer	Products	Stack	Catalog depth
viewer			persistent outbound 443 to vendor cloud	

Group A — HMI panels — Purdue L2 (area supervisory)

- **Direct attack surface:**

- **TCP/502** Modbus master *and* slave — water-utility panels poll the local CompactLogix/M340 *and* answer central-SCADA polls; no auth, no integrity.
- **TCP/80, TCP/443** cMT-X web-UI (admin panel + project download endpoint). Historical default `admin / 111111` — Shodan-discoverable across small municipal water sites.
- **TCP/5900** VNC for remote operator screen — frequently enabled with weak/default password.
- **TCP/8000–8001** Weintek/Maple cloud-relay heartbeat (EasyAccess 2.0). Outbound, but pivot path back into L2 once registered.
- **USB-A** front-panel — project upload, firmware reflash, runtime log dump. Physically reachable in unmanned pump houses.

- **Confirmed CVEs / advisories:**

CVE / Advisory	CVSS	Product	Vector	Status
Weintek cMT PSIRT bulletins	family	Weintek cMT family → Maple cMT-X	Unauth path traversal / file-read in web-HMI (cMT EasyWeb family)	Verify Maple firmware revision against upstream Weintek fix date
Weintek EasyWeb PSIRT bulletins	family	Weintek EasyWeb (cMT) → Maple cMT-X	Auth bypass / command injection in cMT web-UI (EasyWeb family)	Verify Maple rebrand pulled fix
Maple PSIRT index	—	HMC / HMI5000 / EZ	Vendor security bulletin landing page	Monitor
CISA ICS Advisories index	—	Weintek cMT (Maple cMT-X by OEM)	Family-level advisories on unauth command exec and hard-coded creds	Family reference

- **Top attack vector (MITRE ATT&CK ICS):** [T0855 Unauthorized Command Message](#) — adversary reaches the HMI's Modbus slave port (502) from a flat OT VLAN and writes coil/register values that the local PLC trusts because the HMI is a known peer. Pair with [T0812 Default Credentials](#) when the default `admin/111111` web-UI is still live.

Group B — Design tools (EZware Plus, EBPro) — Purdue L3 (site operations / EWS)

- **Direct attack surface:**

- **Project-file parsers:** `.cmtp`, `.empx`, `.mtp` — historically parser-bug-prone (Weintek EBPro disclosed multiple stack/heap issues 2021–2023). Phishing-delivered project file → integrator laptop → lateral into L2 panel on next download.
- **Runtime push channel:** EBPro pushes signed-or-unsigned runtime images over HTTP/USB to the panel; signature enforcement is configurable and historically off-by-default on cMT-X.
- **DLL search-order:** Win32 IDE installed under `C:\MapleSystems\` and `C:\EBPro\` — classic side-loading target.

- **Confirmed CVEs / advisories:**

CVE / Advisory	CVSS	Product	Vector	Status
Weintek EBPro PSIRT bulletins	family	Weintek EBPro (lineage of Maple EBPro)	Project-file parser memory corruption (stack/heap)	Family reference — verify Maple build pulled fix
CISA ICS Advisories index	—	EBPro / EasyBuilder Pro	Family-level project-file parser advisories	Monitor

- **Top attack vector (MITRE ATT&CK ICS):** [T0843 Program Download](#) — weaponized `.cmtp` opened on the integrator's EWS triggers parser bug; integrator then pushes a poisoned runtime to every panel they service that week, including unrelated water districts. Pair with [T0889 Modify Program](#) when the poisoned runtime alters PLC-facing logic on download.

Group C — cMT-Viewer — Purdue L3.5 (IT/OT boundary)

- **Direct attack surface:**

- **Outbound 443 to Weintek/Maple cloud relay** (EasyAccess 2.0 lineage). Once registered, the relay tunnels operator screen + control back to a thin client anywhere on the internet — a clean L3.5 → L2 pivot if relay creds leak.
- **Mobile clients** (iOS/Android cMT-Viewer) cache project credentials locally; lost phone → operator access.

- **Confirmed CVEs / advisories:**

CVE / Advisory	CVSS	Product	Vector	Status
Weintek cMT remote-access PSIRT bulletins	family	Weintek cMT remote-access family	Unauth control via web/remote channel	Family reference

CVE / Advisory	CVSS	Product	Vector	Status
Maple PSIRT index	—	cMT-Viewer	Vendor advisories	Monitor

- **Top attack vector (MITRE ATT&CK ICS):** [T0866 Exploitation of Remote Services](#) — adversary abuses the cloud-relay registration to reach an L2 panel from the internet, bypassing the site firewall entirely, then leverages the relayed operator session to achieve [T0832 Manipulation of View](#).

Water-utility deployment pattern (primary use case)

Maple **HMC4070A / HMC5070A** 7-inch panels are the dominant local operator HMI in municipal pump houses across the PNW and Midwest. The canonical wiring: panel wall-mounted in the chlorine room, serial RS-485 *or* Ethernet to a CompactLogix or Schneider M340 PLC handling pump/valve I/O, and a parallel Modbus TCP slave on 502 answering polls from the central SCADA at the water-district office. Three field realities the DFIR analyst should assume by default: (1) the web-UI still has `admin/111111` because the integrator never rotated it; (2) the panel is on the *same* flat VLAN as the PLC and the office VPN concentrator; (3) the cMT-Viewer / EasyAccess 2.0 relay is registered "for vendor support" and nobody knows the cloud creds. Triage these three before anything else when a Maple HMC4070A is in scope.

Logging matrix (highest priority)

Source	Event	What it catches	MITRE ATT&CK ICS
Network IDS at L2/L3 boundary	Modbus TCP write to coil/holding-register from non-EWS source	Unauthorized command messages targeting the PLC behind the Maple HMI	T0855
Network IDS	New outbound TCP/8000–8001 or 443 to Weintek/Maple cloud-relay endpoints	Unsanctioned EasyAccess 2.0 / cMT-Viewer registration	T0866
Network IDS	HTTP GET/POST to cMT web-UI <code>/admin</code> or <code>/cgi-bin</code> from non-EWS source	Exploitation of cMT EasyWeb auth-bypass / path-traversal class bugs	T0866
Network IDS	VNC (TCP/5900) auth attempts to HMI panel	Default-credential abuse against operator screen	T0812
EWS endpoint (EDR)	<code>EBPro.exe</code> / <code>EZwarePlus.exe</code> opens <code>.cmtp</code> / <code>.empx</code> from <code>%TEMP%</code> or email-	Phishing-delivered project file → poisoned runtime push	T0843

Source	Event	What it catches	MITRE ATT&CK ICS
	quarantine path		
EWS endpoint (EDR)	Child process spawned by <code>EBPro.exe</code> writing to <code>C:\Windows\System32\</code>	DLL side-loading / post-exploit from project parser bug	T0889
HMI panel syslog (if forwarded)	Runtime image flash event outside maintenance window	Unauthorized firmware push from compromised EWS	T0857
Site firewall	New inbound flow to TCP/502 on HMI from outside the PLC's <code>/24</code>	Modbus slave abuse / control-center spoofing	T0830

Secondary:

- Maple/Weintek cMT web-UI access log (`/var/log/httpd-*` on the panel once carved) — login success/failure, project-download paths.
- EasyAccess 2.0 / cMT cloud relay session log (vendor cloud side) — device registration timestamps, source IPs.
- PLC-side audit (CompactLogix Logix-controller log, M340 SYSLOG) — controller mode changes following HMI activity.
- OT-native anomaly: Modbus function-code histogram drift on TCP/502 — sudden appearance of FC 8 (diagnostic) or FC 43 (encapsulated interface) from the HMI is highly atypical.
- USB-insertion telemetry from any wrapping kiosk/jumphost — physical USB to an HMC4070A in a pump house is the most likely real-world initial access.

Specific zero-day-ish concerns for your dataset

1. **Default `admin / 111111` on cMT-X web-UI in production water sites.** Forescout and Team82 have both flagged Weintek-family default creds as a Shodan-grep finding. Assume every Maple cMT-X panel you carve still has it unless the integrator's handover doc explicitly says otherwise. Triage TCP/80 + TCP/443 first ([T0812 Default Credentials](#)).
2. **OEM-lag on Weintek cMT EasyWeb fixes.** Maple rebrands Weintek hardware; security fixes land in Weintek's EBPro / cMT firmware first and arrive in Maple-branded firmware on a delay. The version string on the panel may *look* current while still being vulnerable. Diff the Maple firmware build date against Weintek's patched release date on the [Weintek PSIRT page](#).
3. **`.cmtp` / `.empx` parser bugs on the integrator EWS.** Small water districts share one integrator across many sites — one weaponized project file compromises the EWS, which then pushes poisoned runtimes to every district the integrator services. Treat any `.cmtp` from email or USB as untrusted ([T0843 Program Download](#) → [T0889 Modify Program](#)).

4. **EasyAccess 2.0 / cMT-Viewer cloud relay registered "for vendor support."** This is the cleanest L3.5→L2 pivot in the Maple ecosystem and is almost never inventoried. Look for outbound 8000–8001/443 to Weintek/Maple cloud netblocks from any HMI subnet ([T0866 Exploitation of Remote Services](#)).
5. **Modbus TCP master + slave on the same panel.** The HMC4070A in a pump house typically holds *both* roles on TCP/502. An attacker who reaches the slave can forge writes that the local PLC trusts as if they came from the operator screen. There is no Modbus authentication to fall back on ([T0855 Unauthorized Command Message](#), [T0830 Adversary-in-the-Middle](#)).

Sources

- CISA ICS Advisories index: <https://www.cisa.gov/news-events/cybersecurity-advisories/ics-advisories>
- Maple Systems cybersecurity / PSIRT page: <https://www.maplesystems.com/support/cybersecurity/>
- Weintek security advisories (OEM upstream): <https://www.weintek.com/globalw/Support/Security.aspx>
- NVD CVE search portal: <https://nvd.nist.gov/vuln/search>
- Claroty Team82 research index: <https://claroty.com/team82/research>
- Forescout Vedere Labs research: <https://www.forescout.com/research-labs/>
- Dragos blog (HMI / water-utility threat coverage): <https://www.dragos.com/blog/>
- MITRE ATT&CK for ICS T0812 Default Credentials: <https://attack.mitre.org/techniques/T0812/>
- MITRE ATT&CK for ICS T0830 Adversary-in-the-Middle: <https://attack.mitre.org/techniques/T0830/>
- MITRE ATT&CK for ICS T0832 Manipulation of View: <https://attack.mitre.org/techniques/T0832/>
- MITRE ATT&CK for ICS T0843 Program Download: <https://attack.mitre.org/techniques/T0843/>
- MITRE ATT&CK for ICS T0855 Unauthorized Command Message: <https://attack.mitre.org/techniques/T0855/>
- MITRE ATT&CK for ICS T0857 System Firmware: <https://attack.mitre.org/techniques/T0857/>
- MITRE ATT&CK for ICS T0866 Exploitation of Remote Services: <https://attack.mitre.org/techniques/T0866/>
- MITRE ATT&CK for ICS T0889 Modify Program: <https://attack.mitre.org/techniques/T0889/>